

ARP Poisoning

1 Introdução

Um ataque possível em redes TCP/IP é o ataque por envenenamento das *caches* ARP (*ARP Poisoning*) que consiste na manipulação das *caches*/tabelas do protocolo ARP (*Address Resolution Protocol*). O princípio deste tipo de ataque é o envio, pelo atacante, de mensagens ARP falsas (*ARP Spoofing*) para a rede, para provocar alterações nas tabelas ARP das máquinas vítimas (*ARP Poisoning*), de modo a que todo o tráfego entre as máquinas vítimas sofra um reencaminhamento (por exemplo, passe pelo atacante).

No caso em que o atacante, através do envenenamento das tabelas de ARP, se coloca no meio do tráfego entre dois quaisquer nós, ele concretiza um ataque de intercepção, conhecido como *homem no meio* (*Man-in-the-Middle*, ou MitM). Este ataque implica a associação, na tabela ARP de cada máquina vítima, do endereço MAC do atacante com os endereços IP das restantes máquinas vítima. O atacante, ao receber os pacotes trocados pelas máquinas vítimas, pode optar por encaminhá-los normalmente entre elas (limitando-se o ataque a uma escuta passiva), ou modificar os dados antes de os enviar. O atacante pode também optar por fazer um ataque de negação de serviço (*Denial of Service* – DoS) contra uma vítima ao associar um endereço MAC inexistente ao endereço IP de um interlocutor dessa vítima (por exemplo, ao endereço IP do seu *gateway* por omissão).

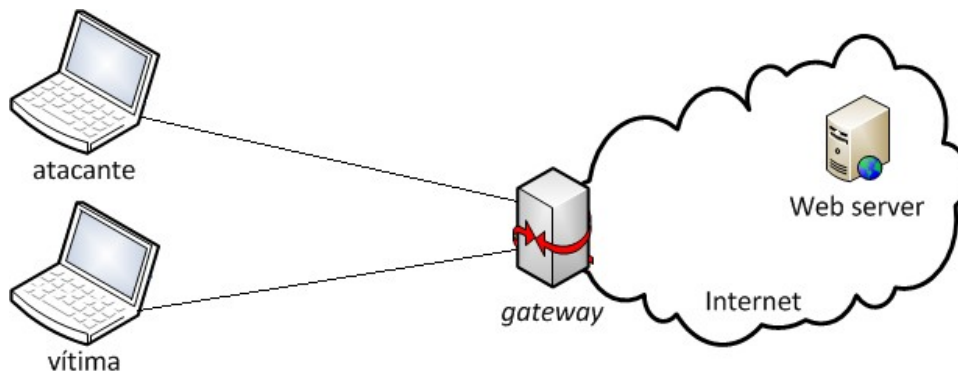


Figura 1: Arquitetura da rede para a demonstração do ataque.

Para a realização deste trabalho é necessário implementar a rede da Figura 1. A máquina atacante deve ser Linux (não se esqueça que o nome da máquina deve conter o seu número mecanográfico da UA e estar visível na prompt da linha de comandos) e a máquina vítima pode ser Windows ou Linux, à escolha.

Coloque todas as capturas de ecrã solicitadas (não se esqueça que aquelas que envolvem a linha de comandos devem mostrar a prompt com o seu número mecanográfico) num documento, do qual deve gerar um pdf que deve ser submetido na página da disciplina na plataforma de ensino a distância da Universidade de Aveiro (elearning.ua.pt).

2 Montagem da rede

Para a realização deste trabalho são necessárias duas máquinas: uma para o papel de vítima e outra para o papel de atacante. Neste guião, estas duas máquinas serão máquinas virtuais e usamos o Virtualbox como

virtualizador (plataforma onde as máquinas virtuais são executadas). Estas duas máquinas serão colocadas dentro de uma rede NAT, semelhante às redes sem fios que temos em nossas casas. Será esta rede NAT que fornecerá o *gateway* que se mostra na Figura 1.

A máquina atacante deve ser uma máquina com uma distribuição Linux (neste guião usamos o Kali Linux mas pode ser outra distribuição, como por exemplo o Ubuntu) e a máquina vítima pode ter um qualquer sistema operativo (Linux, Windows, OS2, ...). Garanta que, qualquer que sejam os sistemas operativos que use, tem o analisador de protocolos Wireshark instalado em ambas as máquinas.

No Gestor do Virtualbox, crie uma rede NAT. Para isso, no menu Ficheiro selecione a opção Ferramentas e depois “Network Manager”. Na aba “NAT Networks” clique com o botão direito do rato sobre a lista de redes NAT (vazia) e selecione a opção “Criar...”. Pode manter a rede sugerida (10.0.2.0/24) e clique Ok para criar a rede. Caso a sua versão do Virtualbox não tenha o Network Manager, é necessário primeiro criar a rede NAT através da linha de comandos usando o seguinte comando:

```
VBoxManage natnetwork add --netname natnet1 --network "10.0.2.0/24" --enable --dhcp on
```

```
VBoxManage natnetwork start --netname natnet1
```

Nas definições de rede das suas duas máquinas virtuais (vítima e atacante) associe o adaptador a “Rede NAT” e garanta que o nome da rede NAT associada é a que atrás criou.

Inicie a sua máquina vítima e anote os respetivos endereço IP, endereço MAC, e endereço IP do *gateway*. Garanta que os endereços IP estão todos dentro da gama de endereços definida para a rede NAT.

Inicie a máquina atacante e garanta que o endereço IP da máquina e do *gateway* pertencem à rede NAT que criou. Anote os referidos endereços IP e também o endereço MAC do adaptador.

Usando o comando ping, teste a conectividade entre as duas máquinas virtuais e entre estas e o site da Universidade de Aveiro (UA) (www.ua.pt). Garanta que existe conectividade entre elas antes de prosseguir com o trabalho. Apresente capturas de ecrã mostrando essa conectividade.

3 Situação anterior ao ataque

Tome nota dos endereços MAC das máquinas vítima e atacante.

Faça um ping da máquina vítima para a página Web da UA. Verifique a *cache* ARP da máquina vítima, usando o comando “**arp -n**” ou “**arp -a**” (consoante ela seja Linux ou Windows, respetivamente), analise-a e apresente a captura de ecrã com o resultado deste comando.

Ative o analisador de pacotes Wireshark na máquina atacante e na máquina vítima. Inicie uma captura de tráfego, em ambas as máquinas, e use o filtro “icmp” para mostrar apenas pacotes ICMP. Na máquina vítima faça ping para a página Web da UA. Depois de alguns pings, termine-os e termine a captura no Wireshark, em ambas as máquinas. Apresente capturas de ecrã, de ambas as máquinas, com o tráfego capturado pelo Wireshark. Analise e comente o tráfego capturado.

Faça um novo ping da máquina vítima para a página Web da UA. Veja a tabela de ARP da máquina vítima, usando o comando arp adequado, como indicado acima, faça uma captura de ecrã ao seu conteúdo e apresente-a.

4 Preparação do ataque

Configure a máquina atacante para reencaminhar o tráfego recebido, usando o seguinte comando:

```
sudo sysctl net.ipv4.conf.all.forwarding=1
```

Tenha em atenção que a alteração acima não é persistente, ou seja, da próxima vez que iniciar a máquina o parâmetro acima já não tem o valor 1, pelo que terá de dar novamente o comando se ainda pretender que a máquina faça o reencaminhamento do tráfego.

Ainda na máquina atacante instale o pacote dsniff, usando o comando:

```
sudo apt-get install dsniff
```

5 Realização do ataque de envenenamento

Neste trabalho pretende-se envenenar as tabelas (*caches*) ARP da máquina vítima e do servidor Web, de modo que todo o tráfego entre estes seja encaminhado para a máquina do atacante. Desta forma, o atacante interceptará todo o tráfego entre a vítima e o servidor web. Para o efeito, na máquina atacante dê os seguintes comandos em janelas de linha de comandos diferentes:

```
sudo arpspoof -t <IP vítima> <IP Gateway>
```

```
sudo arpspoof -t <IP Gateway> <IP vítima>
```

Com o primeiro comando faz o envenenamento da tabela de ARP da máquina vítima e com o segundo faz o envenenamento da tabela de ARP do Gateway. O envenenamento é feito através do envio, pelo atacante, de pacotes ARP Reply com informação falsa. Com o primeiro comando, informa a vítima que o Gateway tem o endereço MAC do atacante e, com o segundo comando, informa o Gateway que a vítima tem o endereço MAC do atacante.

Ainda com o ataque a decorrer, verifique a tabela de ARP da máquina vítima, apresente uma captura de ecrã com ela, e analise e comente o seu conteúdo.

Ainda com o ataque a decorrer, utilizando o Wireshark, inicie capturas de tráfego na máquina vítima e na máquina atacante, usando o filtro “arp”. Faça uma captura do tráfego capturado em ambas as máquinas e apresente-as comentando o que observa, tendo em particular atenção os endereços MAC e IP dos pacotes.

Ainda com o ataque a decorrer, altere o filtro do Wireshark, em ambas as máquinas, para “icmp” e inicie uma nova captura. Faça ping da máquina vítima para o servidor Web da UA. Depois de capturar os pacotes de alguns pings, termine as capturas de tráfego, o ping e o ataque. Faça capturas de ecrã para mostrar o tráfego capturado em ambas as máquinas e apresente-as. Analise as capturas de tráfego nas duas máquinas e compare-as com as obtidas antes do lançamento do ataque (secção 3) e explique o que observa.

6 Outras ferramentas de ataque

A ferramenta arpspoof que usou não é muito sofisticada e apenas implementa o ataque, não incluindo funcionalidades para tirar partido do ataque. No entanto, existem outras ferramentas mais sofisticadas que o fazem, como é o caso do Ettercap, que vem incluído no Kali Linux.

Usando informação disponível na Internet, instale o Ettercap na máquina atacante. O Ettercap inclui plugins que permitem a realização de vários ataques. Explore a informação sobre os ataques e implemente um à sua escolha. Apresente os resultados do ataque através de capturas de ecrã.

7 Bibliografia

ARP poisoning, http://en.wikipedia.org/wiki/ARP_spoofing.

Ettercap, [https://en.wikipedia.org/wiki/Ettercap_\(software\)](https://en.wikipedia.org/wiki/Ettercap_(software))